

The Payment Card Industry Data Security Standard (PCI DSS) is a global data security standard that regulates how entities store, process, and transmit cardholder data (CHD) and/or sensitive authentication data (SAD). PCI DSS includes guidelines regarding components of organizations' technical and operational system that are related to such data. Cardholder Data refers to information including Primary Account Numbers (PAN), cardholder names, expiration dates, and service codes. Sensitive authentication data refers to information including "full track data (magnetic-stripe data or equivalent on a chip)," card verification codes, and PINs/PIN blocks. This standard is administered by the Payment Card Industry Security Standards Council, and its use is enforced by the major payment card brands. PCI DSS was created to improve and streamline the security controls organizations use when handling cardholder data and reduce credit card fraud. These organizations, including merchants and service providers, must prove compliance to the PCI DSS through an assessment and validation process. The payment card brands issue fines and other penalties when merchants or service providers fail to prove compliance. Validation of compliance is performed annually or quarterly with a method suited to the organization's volume of transactions:

Self-assessment questionnaire (SAQ)

Firm-specific Internal Security Assessor (ISA)

External Qualified Security Assessor (QSA)

## History

Before the PCI DSS was launched, payment card information security was handled by the five major payment card brands: Visa, Mastercard, American Express, Discover, and JCB. They each had different independent security programs:

Visa's Cardholder Information Security Program

Mastercard's Site Data Protection

American Express's Data Security Operating Policy

Discover's Information Security and Compliance

JCB's Data Security Program

The intentions of each were roughly similar: to create an additional level of protection for card issuers by ensuring that merchants meet minimum levels of security when they handle payment cards and related account information. As payment card fraud rose in the late 1990s and early 2000s, the major payment card brands felt a growing need to streamline and unify these information security standards. Each program had its own methods and guidance regarding compliance validation, assessments, and requirements. To address interoperability problems among the existing standards, the combined effort by these payment card brands resulted in the release of version 1.0 of PCI DSS in December 2004. The main payment card brands then founded the Payment Card Industry Security Standards Council (PCI SSC) and aligned their policies to create the PCI DSS. PCI DSS has since been implemented and followed by numerous organizations around the world.

MasterCard, American Express, Visa, JCB International and Discover Financial Services established the PCI SSC in September 2006 as a global administrative and governing entity that mandates the evolution and development of the PCI DSS. Independent private organizations can also participate in PCI development as part of the PCI Security Standards Council Participating Organization Program. To join that program, organizations must register as a PCI SSC Participating Organization (PO). Each participating organization joins a SIG (Special Interest Group) and contributes to activities mandated by the group.

The PCI DSS is a living document that is regularly updated by the PCI Security Standards Council. The PCI SSC releases major version updates, such as version 4.0, approximately every few years. Minor updates, such as version 4.0.1, are released more frequently and typically add small changes or clarifications. When updates are released, organizations have a

transition period during which they must become familiar with the new changes and begin ensuring compliance with the current version. During the transition period, organizations are only required to be compliant with either the current version or the previous version. The following versions of the PCI DSS have been made available:

#### Requirements and control objectives

The PCI DSS has twelve requirements for compliance, organized into six related groups known as control objectives:

Build and maintain a secure network and systems

Protect cardholder data

Maintain a vulnerability management program

Implement strong access control measures

Regularly monitor and test networks

Maintain an information security policy

Each PCI DSS version has divided these six requirement groups differently, but the twelve requirements have not changed since the inception of the standard. Each requirement and sub-requirement is divided into three sections:

PCI DSS requirements: Define the requirement. The PCI DSS endorsement is made when the requirement is implemented.

Testing: The processes and methodologies carried out by the assessor for the confirmation of proper implementation.

Guidance: Explains the purpose of the requirement and the corresponding content, which can assist in its proper definition.

In version 4.0.1 of the PCI DSS, the twelve requirements are:

Install and maintain network security controls.

Apply secure configurations to all system components.

Protect stored account data.

Protect cardholder data with strong cryptography during transmission over open, public networks.

Protect all systems and networks from malicious software.

Develop and maintain secure systems and software.

Restrict access to system components and cardholder data by business need to know.

Identify users and authenticate access to system components.

Restrict physical access to cardholder data.

Log and monitor all access to system components and cardholder data.

Test security of systems and networks regularly.

Support information security with organizational policies and programs.

Updates and supplemental information

The PCI SSC (Payment Card Industry Security Standards Council) has released supplemental information to clarify requirements, which includes:

Information Supplement: Requirement 11.3 Penetration Testing

Information Supplement: Requirement 6.6 Code Reviews and Application Firewalls Clarified

Navigating the PCI DSS - Understanding the Intent of the Requirements

PCI DSS Wireless Guidelines

PCI DSS Applicability in an EMV Environment

Prioritized Approach for PCI DSS

Prioritized Approach Tool

PCI DSS Quick Reference Guide

PCI DSS Virtualization Guidelines

PCI DSS Tokenization Guidelines

PCI DSS 2.0 Risk Assessment Guidelines

The lifecycle for Changes to the PCI DSS and PA-DSS

Guidance for PCI DSS Scoping and Segmentation

PCI DSS v4.0 Resource Hub

PCI DSS Summary of Changes: v4.0 to v4.0.1

## Merchant levels

Merchants that store, process, and transmit cardholder data are subject to PCI DSS standards, and thus, must be deemed PCI-compliant. The PCI DSS framework classifies these entities into merchant levels that determine the type of reporting a business must complete to achieve compliance. A business' merchant level is determined by its dataset size which refers to the number of transactions a business makes annually. An acquirer or payment brand may manually place an organization into a reporting level at its discretion. Not all payment card brands use all four merchant levels, and each level's transaction volume can vary among payment card brands. For instance, Visa only has three merchant levels. The four typically accepted merchant levels are:

Level 1 – Over six million transactions annually

Level 2 – Between one and six million transactions annually

Level 3 – Between 20,000 and one million transactions annually, and all e-commerce merchants

Level 4 – Less than 20,000 transactions annually

Each card issuer maintains a table of compliance levels and a table for service providers.

## Service provider levels

According to the PCI DSS, third-party service providers that store, process, or transmit cardholder data, or have access to customers' account data are subject to PCI DSS standards. Service providers can include payment software vendors, software as a service (SaaS), data centers, and other such entities. Service providers are required to prove PCI DSS compliance through the assessment process. The type of reporting process a service provider must complete are dependent on the type of service provider. Service providers are classified into levels which determine the reporting required for compliance. The two service provider levels are:

### Level 1:

All Third-Party Processors (TPPs)

All Staged Digital Wallet Operators (SDWOs)

All Digital Activity Service Providers (DASPs)

All Business Payment Service Providers (BPSPs)

All Token Service Providers (TSPs)

All 3-D Secure Service Providers (3-DSSPs)

All Installment Service Providers (ISPs)

All Merchant Payment Gateways (MPGs)

All AML/Sanctions Service Providers, Data Storage Entities (DSEs) and Payment Facilitators (PFs) with more than 300,000 total combined Mastercard and Maestro transactions annually

### Level 2:

All AML/Sanctions Service Providers, DSEs and PFs with 300,000 or less total combined Mastercard and Maestro transactions annually

All Terminal Servicers (TSs)

## Compliance

The payment card brands regularly require both merchants and service providers to demonstrate PCI DSS compliance. PCI DSS compliance involves implementing security controls that follow all requirements of the PCI DSS and passing the PCI DSS assessment process to achieve compliance validation. The major credit card brands enforce PCI DSS compliance by issuing fines for merchants who do not obtain compliance validation. Merchants and service providers sign business-to-business contracts with payment processors and payment card brands, which outline such fines and fees. In the event of a merchant's compliance violation, payment card brands issue fines to the acquiring bank who then fines or otherwise penalizes the non-compliant merchant. Obtaining PCI DSS compliance and navigating the assessment process can be complicated, which is why many businesses often struggle with this. According to Verizon's 2018 Payment Security Report, 47.5% of organizations were not PCI DSS compliant during interim compliance validation. The number of organizations achieving compliance had been steadily increasing through the early 2010s, but this increase may likely have dropped in recent years.

## Compliance validation

Compliance validation involves the evaluation and confirmation that the security controls and procedures have been implemented according to the PCI DSS. Validation occurs through an annual assessment, either by an external entity, or by self-assessment. The assessment process includes the following steps:

Confirm the scope of the PCI DSS assessment.

Perform the PCI DSS assessment of the environment.

Complete the applicable report for the assessment according to PCI DSS guidance and

instructions.

Complete the Attestation of Compliance for Service Providers or Merchants, as applicable, in its entirety.

Submit the applicable PCI SSC documentation and the Attestation of Compliance, along with any other requested documentation to the requesting organization (those that manage compliance programs such as payment brands and acquirers (for merchants), or other requesters (for service providers)).

### Report on Compliance

A Report on Compliance (ROC) is conducted by a PCI Qualified Security Assessor (QSA) and is intended to provide independent validation of an entity's compliance with the PCI DSS standard. A completed ROC results in two documents: a ROC Reporting Template populated with detailed explanation of the testing completed, and an Attestation of Compliance (AOC) documenting that a ROC has been completed and the overall conclusion of the ROC.

### Self-Assessment Questionnaire

The PCI DSS Self-Assessment Questionnaire (SAQ) is a validation tool intended for small to medium sized merchants and service providers to assess their own PCI DSS compliance status. There are multiple types of SAQ, each with a different length depending on the entity type and payment model used. Each SAQ question has a yes-or-no answer, and any "no" response requires the entity to indicate its future implementation. As with ROCs, an attestation of compliance (AOC) based on the SAQ is also completed.

### Security Assessors

The PCI Security Standards Council maintains a program to certify companies and individuals to perform assessment activities.

## Qualified Security Assessor

A Qualified Security Assessor (QSA) is an individual certified by the PCI Security Standards Council to validate another entity's PCI DSS compliance. QSAs must be employed and sponsored by a QSA Company, which also must be certified by the PCI Security Standards Council.

## Internal Security Assessor

An Internal Security Assessor (ISA) is an individual who has earned a certificate from the PCI Security Standards Council for their sponsoring organization, and can conduct PCI self-assessments for their organization. The ISA program was designed to help Level 2 merchants meet Mastercard compliance validation requirements. ISA certification empowers an individual to conduct an appraisal of his or her association and propose security solutions and controls for PCI DSS compliance. ISAs are in charge of cooperation and participation with QSAs.

## Compliance versus validation of compliance

Although the PCI DSS must be implemented by all entities which process, store or transmit cardholder data and/or sensitive authentication data or could impact the security of such information, formal validation of PCI DSS compliance is not mandatory for all entities. Visa and Mastercard require merchants and service providers to be validated according to the PCI DSS; Visa also offers a Technology Innovation Program (TIP), an alternative program which allows qualified merchants to discontinue the annual PCI DSS validation assessment. Merchants are eligible if they take alternative precautions against fraud, such as the use of EMV or point-to-point encryption.

Issuing banks are not required to undergo PCI DSS validation, although they must secure

sensitive data in a PCI DSS-compliant manner. Acquiring banks must comply with PCI DSS and have their compliance validated with an audit. In a security breach, any compromised entity which was not PCI DSS-compliant at the time of the breach may be subject to additional penalties (such as fines) from card brands or acquiring banks.

### Legal status

No governing body/agency requires or enforces PCI DSS compliance, but if any PCI DSS requirements conflict with country, state, or local law, the law will apply. The European Union's (EU) General Data Protection Regulation (GDPR) is a legislative standard governing personal data. GDPR has similar security control standards as PCI DSS in regards to cardholder data because cardholder data is considered a form of personal data under GDPR. Hence, for many European organizations, a PCI DSS breach often constitutes a GDPR breach as well, which can result in fines from both major payment card brands and the European Union. These GDPR fines can be up to "€20 million or 4% of annual global turnover" (whichever is greatest).

### Legislation in the United States

While compliance with PCI DSS is not required by federal law in the United States, the laws of some US states refer to PCI DSS directly or make equivalent provisions. In 2007, Minnesota enacted a law prohibiting the retention of some types of payment-card data more than 48 hours after authorization of a transaction. Nevada incorporated the standard into state law two years later, requiring compliance by merchants doing business in that state with the current PCI DSS and shielding compliant entities from liability. The Nevada law also allows merchants to avoid liability by other approved security standards. In 2010, Washington also incorporated the standard into state law. Unlike Nevada's law, entities are not required to be PCI DSS-compliant; however, compliant entities are shielded from liability in the event of a data breach. Legal scholars Edward Morse and Vasant Raval have said that by enshrining PCI

DSS compliance in legislation, card networks reallocated the cost of fraud from card issuers to merchants.

### Controversy and criticism

The major payment card brands impose fines for non-compliance. Some business owners, small business owners especially, criticize the PCI DSS system because the payment card brands impose fines on businesses even if no fraud occurs. Stephen and Theodora "Cissy" McComb, owners of a small restaurant called Cisero's Ristorante and Nightclub in Park City, Utah, were fined for a breach for which two forensics firms could not find evidence. They claim the PCI DSS system exists primarily for major card brands to extract profit from these merchant companies rather than ensure cardholder data security.

Michael Jones, who was CIO of Michaels at the time, testified before a US Congressional subcommittee about the PCI DSS:

[The PCI DSS requirements] are very expensive to implement, confusing to comply with, and ultimately subjective, both in their interpretation and in their enforcement. It is often stated that there are only twelve "Requirements" for PCI compliance. In fact there are over 220 sub-requirements; some of which can place an incredible burden on a retailer and many of which are subject to interpretation.

Proponents of the PCI DSS maintain that the PCI DSS may compel businesses to pay more attention to IT security, even if minimum standards are not enough to eradicate security problems. Bruce Schneier spoke in favor of the standard:

Regulation—SOX, HIPAA, GLBA, the credit-card industry's PCI, the various disclosure laws, the European Data Protection Act, whatever—has been the best stick the industry has found to beat companies over the head with. And it works. Regulation forces companies to take

security more seriously, and sells more products and services.

PCI Council general manager Bob Russo responded to objections by the National Retail Federation:

[PCI is a structured] blend ... [of] specificity and high-level concepts [that allows] stakeholders the opportunity and flexibility to work with Qualified Security Assessors (QSAs) to determine appropriate security controls within their environment that meet the intent of the PCI standards.

Former Visa chief enterprise risk officer Ellen Richey said in 2018, "No compromised entity has yet been found to be in compliance with PCI DSS at the time of a breach". However, a 2008 breach of Heartland Payment Systems (validated as PCI DSS-compliant) resulted in the compromising of more than one hundred million card numbers. Around that time, Hannaford Brothers and TJX Companies (also validated as PCI DSS-compliant) were similarly breached as a result of the allegedly-coordinated efforts of Albert Gonzalez and two unnamed Russian hackers. In December 2013, more than forty million Target customer accounts were compromised in a data breach. Target's Executive Vice President and Chief Financial Officer at the time John Mulligan confirmed that Target was certified PCI compliant months before the breach in September 2013. News of incidents was widespread and called into question the adequacy of the PCI DSS.

Assessments examine the compliance of merchants and service providers with the PCI DSS at a specific point in time, frequently using sampling to allow compliance to be demonstrated with representative systems and processes. It is the responsibility of the merchant and service provider to achieve, demonstrate, and maintain compliance throughout the annual validation-and-assessment cycle across all systems and processes. A breakdown in merchant and service-provider compliance with the written standard may have been responsible for the breaches; Hannaford Brothers received its PCI DSS compliance validation one day after it had

been made aware of a two-month-long compromise of its internal systems.

Compliance validation is required only for level 1 to 3 merchants and may be optional for Level 4, depending on the card brand and acquirer. According to Visa's compliance validation details for merchants, level-4 merchant compliance-validation requirements ("Merchants processing less than 20,000 Visa e-commerce transactions annually and all other merchants processing up to 1 million Visa transactions annually") are set by the acquirer. Over 80 percent of payment-card compromises between 2005 and 2007 affected level-4 merchants, who handled 32 percent of all such transactions.

See also

Card scheme

Penetration test

Vulnerability management

Wireless LAN

Wireless security

References

External links

Official PCI Security Standards Council Site